CYBERSECURITY LAB ACTIVITY

OWASP Juice Shop
Gobuster, Wordlists & SecLists

Practical Web Content Discovery and Evidence Review

Student name	_____
Course / section	_____
Instructor	_____
Activity date	_____

Training target: http://127.0.0.1:3000

1. Introduction

This activity used OWASP Juice Shop, an intentionally vulnerable web application designed for security education, to practice basic web content discovery. Gobuster was used with a wordlist from SecLists to request likely paths on the local training instance. The discovered paths were then reviewed in the browser to understand what the responses did—and did not—demonstrate.

Objectives

- Explain the purpose of OWASP Juice Shop as a safe, intentionally vulnerable training application.
- Understand Gobuster directory enumeration and how it uses a wordlist.
- Identify SecLists as a collection of reusable security-testing wordlists.
- Interpret HTTP status codes and validate scan results manually.
- Record evidence and discuss responsible, authorized testing.

2. Tools and Concepts

OWASP Juice Shop

OWASP Juice Shop is a deliberately insecure web application used to learn and practice web application security. In this activity, the instance was accessed locally at 127.0.0.1:3000, keeping testing within the lab environment.

Gobuster

Gobuster is a command-line tool that tests candidate names from a wordlist against a target web server. In directory mode, it can reveal paths that respond, redirect, or produce errors. It does not prove that a path is vulnerable; each meaningful result must be inspected and understood.

Wordlist

A wordlist is a text file containing candidate directory or file names. Gobuster tries each entry as part of a URL. The list influences what can be discovered: a short list is faster but may miss paths, while a larger list can take longer and produce more noise.

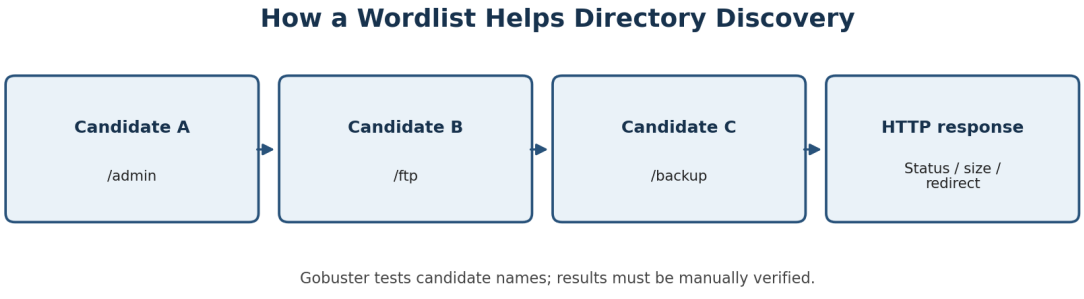


Figure 1. Conceptual flow: Gobuster tests candidate paths and evaluates HTTP responses.

SecLists

SecLists is a collection of wordlists commonly used in authorized security assessments. The screenshot from this activity shows the Web-Content list at /usr/share/seclists/Discovery/Web-Content/common.txt. The common.txt file contains frequently used web path names and is suitable for a first, relatively small discovery pass.

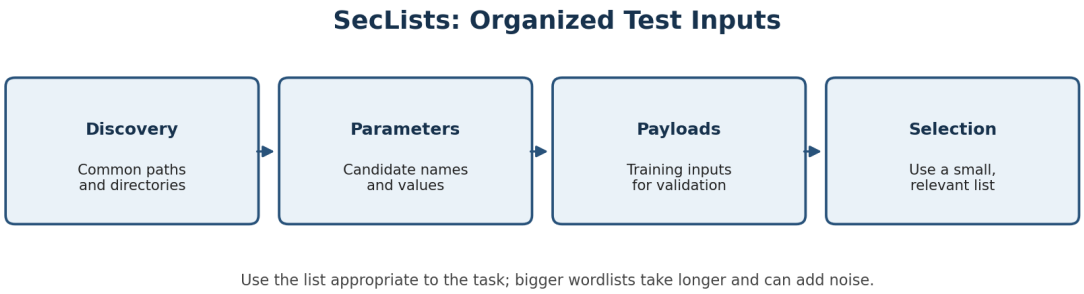


Figure 2. SecLists is a reusable collection of wordlists for different security-testing tasks.

3. Lab Setup and Method

The workflow shown by the activity screenshots was:

- Open the OWASP Juice Shop instance in Firefox and confirm that the local site loads.
- Run Gobuster against the local URL using the SecLists common web-content wordlist.
- Use a low request rate (two threads and a 500 ms delay) to keep the local test controlled.
- Review returned paths and response codes, then open selected results in the browser.
- Record screenshots and distinguish observed behavior from conclusions that require more testing.

Command used

```
gobuster dir \
  -u http://127.0.0.1:3000 \
  -w /usr/share/seclists/Discovery/Web-Content/common.txt \
  -t 2 \
  --delay 500ms \
  --exclude-length 9984
```

The command targets only the local Juice Shop instance. The delay and low thread count reduce request rate. The exclude-length option filters responses with a matching body length; it can reduce repetitive fallback results, but it can also hide a real path if its response happens to have that same length.

4. Results and Screenshot Evidence

4.1 Gobuster scan results

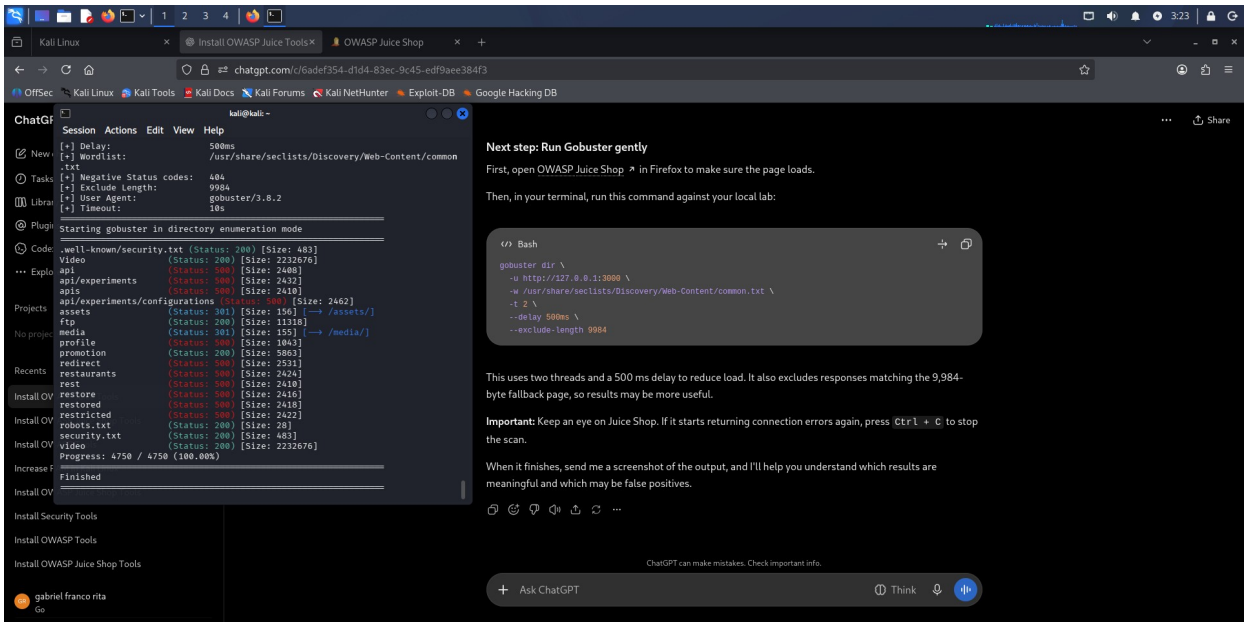


Figure 3. User-provided screenshot showing Gobuster output and scan completion.

The terminal output shows the scan completed 4,750 of 4,750 entries. Reported paths include ftp, robots.txt, assets, media, video, and other names. The screenshot includes HTTP 200, 301, and 500 responses. A 200 response usually means the request succeeded; 301 indicates a redirect; 500 indicates a server-side error. A 500 result is not, by itself, proof of a vulnerability. It should be investigated only within the authorized lab.

4.2 Reviewing the /ftp directory

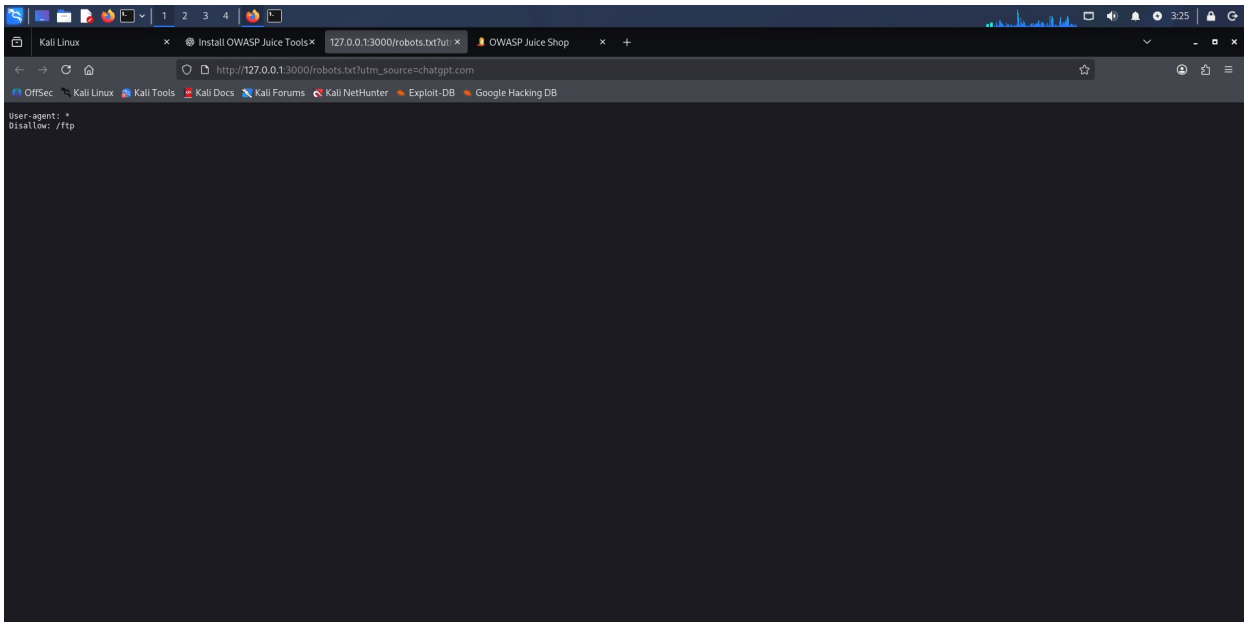


Figure 4. Browser view from the lab while reviewing the discovered FTP-related content.

The activity included reviewing the /ftp path discovered by Gobuster. Publicly reachable file directories can expose documents or internal naming information. The security impact depends on the actual files and whether they were intended to be public.

4.3 File-type restriction response

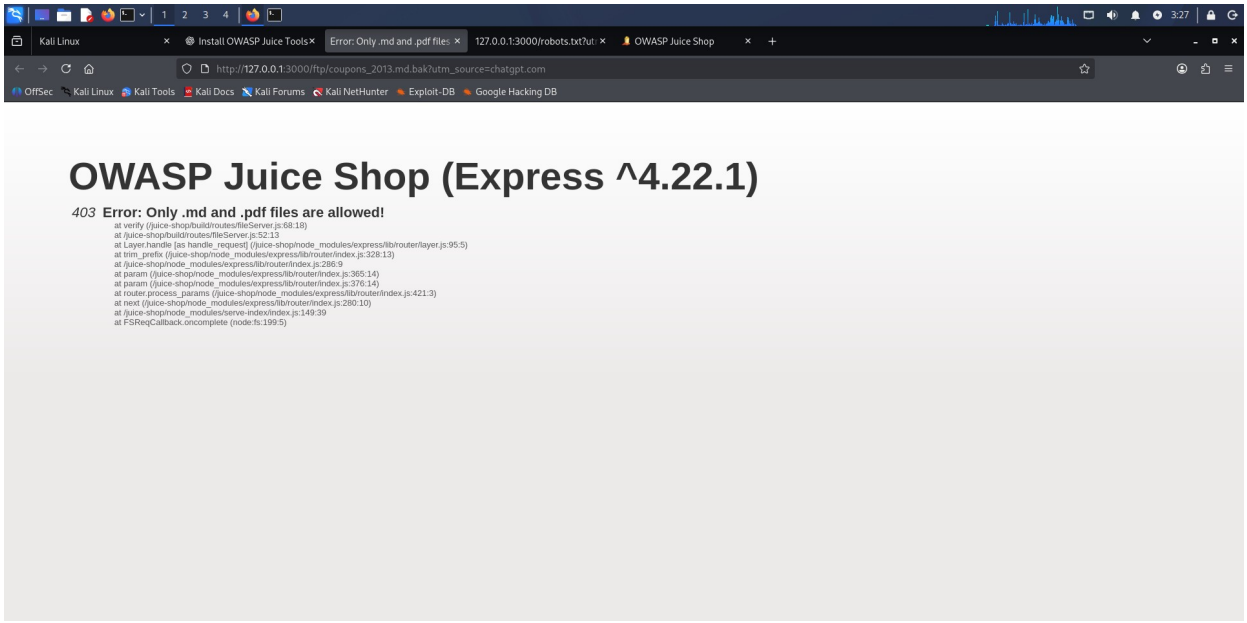


Figure 5. Juice Shop returned a 403 message stating that only .md and .pdf files are allowed.

The response demonstrates that the application rejected this particular request based on its file-type rules. It does not prove every file request is handled securely. Strong file handling also requires authorization checks, safe storage, and validation on the server.

4.4 Reading a Markdown file

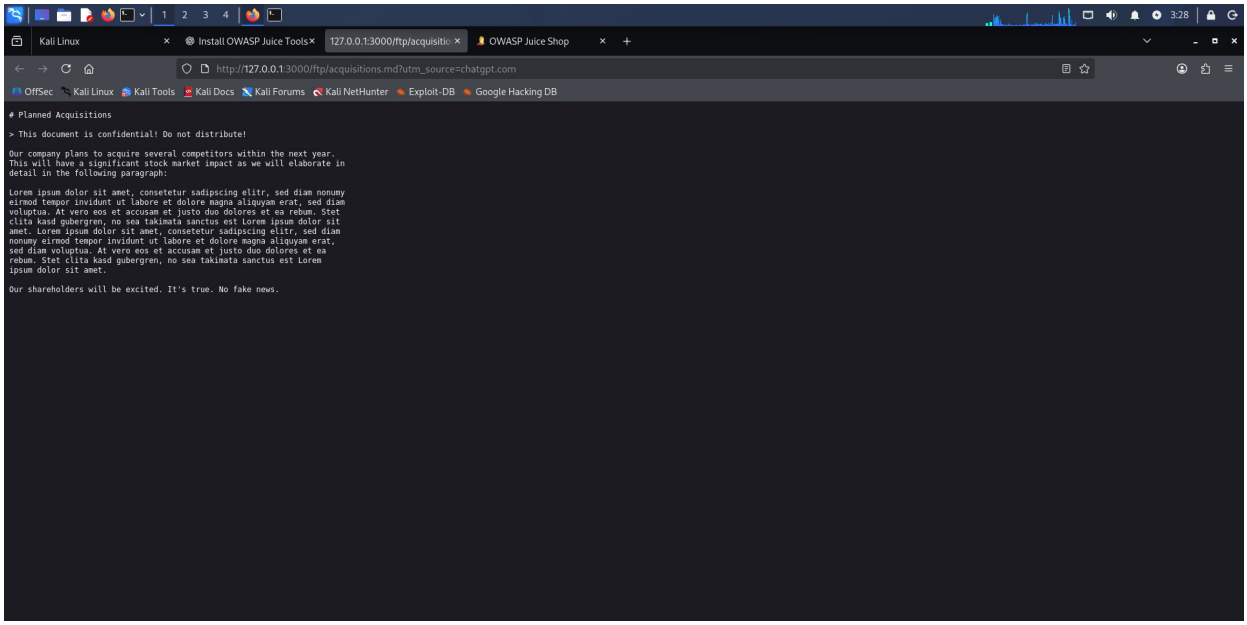


Figure 6. The legal.md document displayed in the browser as text.

The legal.md file could be viewed as plain text. This illustrates why teams should review which files are stored in publicly reachable directories and confirm that published content contains no sensitive information.

4.5 Numeric announcement file

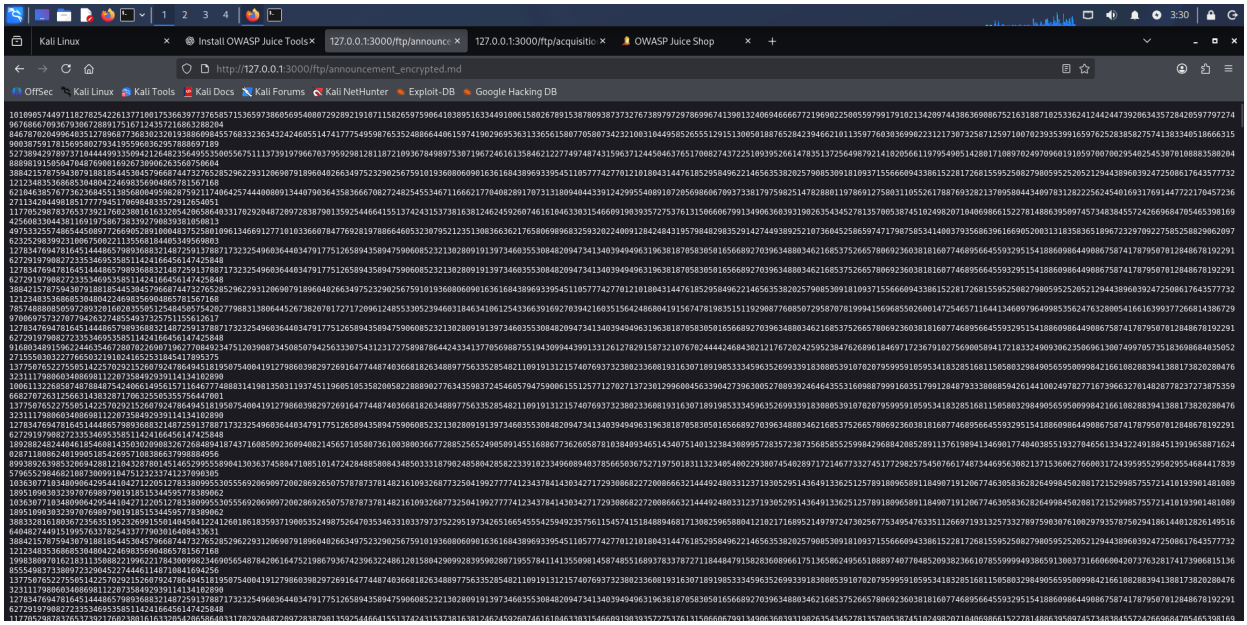


Figure 7. The announcement file appears as a long numeric stream.

The numeric file was inspected with basic command-line and Python checks. The recorded output counted 368,043 digits and examined digit frequencies, group sizes, and repeated sequences. These are exploratory format checks only: they do not identify a cipher or demonstrate successful decryption. A sound report should avoid claiming a decryption result unless the recovered message can be verified.

4.6 Score Board and coding challenge

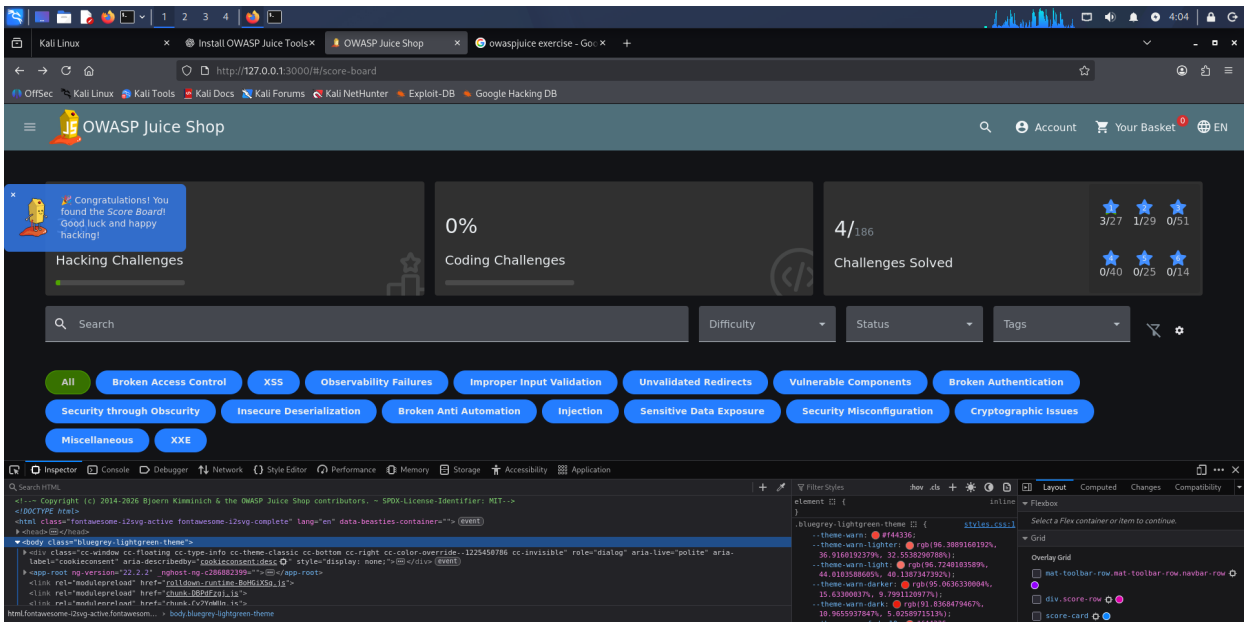


Figure 8. The Juice Shop Score Board shows 4 of 186 challenges solved.

The Score Board screenshot confirms that the Score Board was found and shows progress at the time of capture: 4 of 186 challenges solved. The Score Board helps organize learning objectives and record progress.

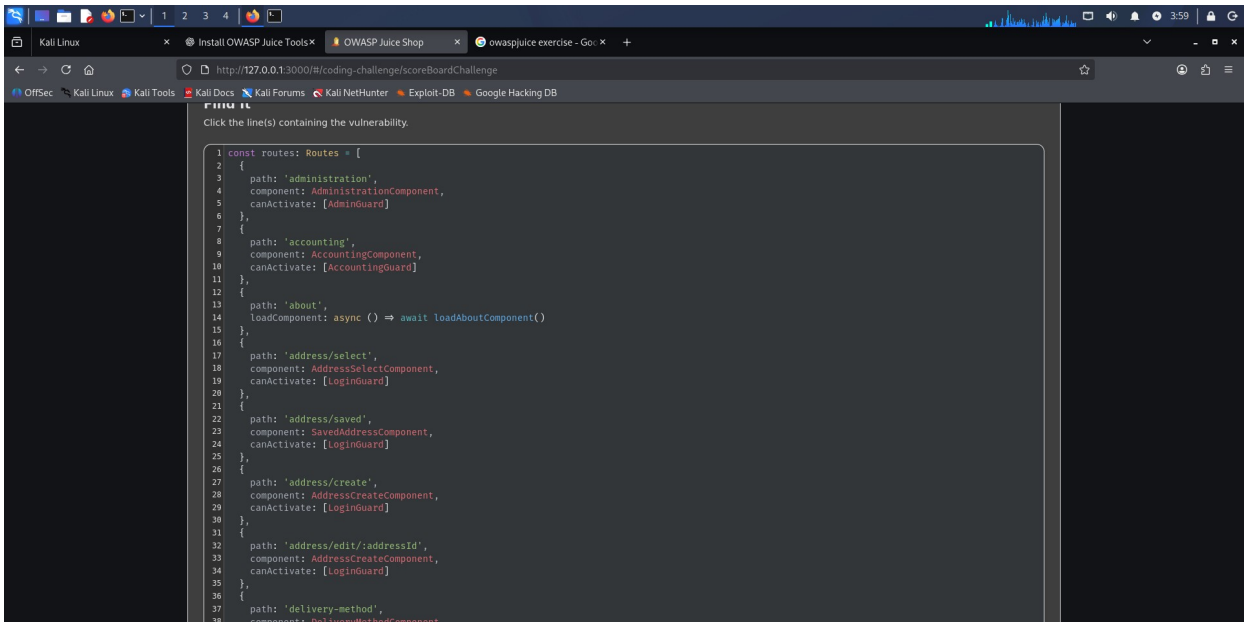


Figure 9. Coding challenge screenshot showing client-side route definitions and guards.

The code view contains route names and client-side guards. This can support a discussion of front-end navigation, but client-side code alone does not establish an authorization bypass. Sensitive operations must enforce access control on the server as well.

5. Key Findings

- Gobuster completed the configured scan against the local Juice Shop training target.
- The SecLists common web-content wordlist supplied candidate paths for the scan.
- The /ftp path and several other paths appeared in the output and were selected for browser review.
- HTTP response codes require context: 200, 301, and 500 each describe different response behavior, not a vulnerability rating.
- The application showed a file-extension restriction response for one request and displayed legal.md as readable text.
- The numeric announcement file was analyzed structurally, but no encryption method or plaintext was confirmed by the recorded checks.
- The Score Board showed 4 of 186 challenges solved at the time of the screenshot.

6. Conclusion

This activity demonstrated a basic web content discovery workflow using OWASP Juice Shop, Gobuster, a wordlist, and SecLists. The main lesson is that automated scanning produces leads, not final conclusions. Responsible testing requires manually validating results, recording evidence, understanding false positives, and keeping activity within the authorized lab environment.

Safety and scope

All testing described here was directed at the local training instance, http://127.0.0.1:3000. Only scan systems you own or have explicit permission to test. Do not reuse these techniques against public systems without authorization.

7. Short Glossary

Term	Meaning
Gobuster	A command-line tool for discovering paths and other resources by testing candidate names.
Wordlist	A text file of candidate names used by tools such as Gobuster.
SecLists	A collection of wordlists used in authorized security testing.
HTTP 200	The request was successful according to the server response.
HTTP 301	The requested resource redirects to another location.
HTTP 403	The server refuses to fulfill the request.
HTTP 500	The server encountered an error while handling the request.
False positive	A result that appears meaningful but does not represent the suspected issue after validation.